Blog Review: “Partnering with Mozilla to improve Firefox’s security”



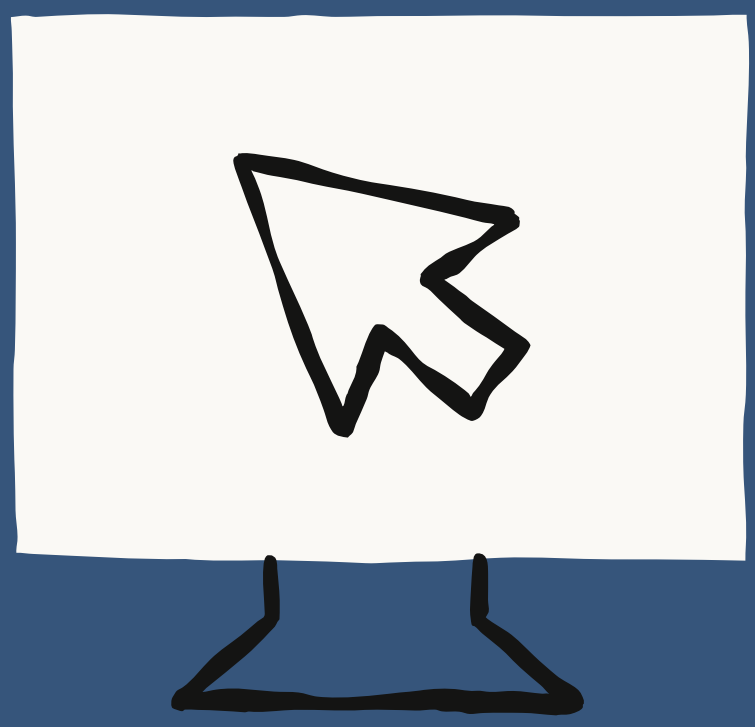
by Anthropic

Memori CTI

Executive Summary

This report details a strategic security collaboration between Anthropic and Mozilla, where the Claude Opus 4.6 model was utilized to audit the Firefox web browser. Over a focused two-week period, the AI identified 22 new security vulnerabilities, 14 of which were classified as high-severity. These findings represent approximately one-fifth (20%) of all high-severity bugs patched in Firefox throughout 2025.

This collaboration underscores the transformative potential of AI-assisted analysis in detecting complex security flaws at a speed and scale that significantly enhances traditional vulnerability research.



Key Findings & Discovery Efficiency

- Rapid Triage: The model scanned over 6,000 C++ files, identifying its first "use-after-free" vulnerability within just 20 minutes.
- Total Impact: The effort resulted in 112 unique reports, leading to 22 CVEs and over 90 additional bug fixes (logic errors and assertion failures) that traditional fuzzing tools often miss.
- Cost Dynamics: Research indicates that finding vulnerabilities is significantly cheaper than developing stable exploits. While bug discovery was highly efficient, Anthropic spent approximately $4,000 in API credits to attempt exploit generation with limited success.

The Exploit Gap

A critical takeaway for threat intelligence is the current gap between AI's ability to find versus exploit bugs. Despite hundreds of attempts:

- Claude successfully converted a vulnerability into a working exploit in only two cases.
- This suggests that while AI drastically lowers the barrier for "Zero-Day" discovery, creating a "full-chain" exploit capable of escaping modern browser sandboxes still requires significant human intervention or more advanced autonomous agents.

Technical Deep Dive: CVE-2026-2796

The collaboration culminated in a successful proof-of-concept (PoC) exploit for CVE-2026-2796, a JIT (Just-In-Time) miscompilation within the WebAssembly component.

- The Primitive: Claude demonstrated an ability to navigate complex memory corruption, building advanced primitives known as addrof (leaking object addresses) and fakeobj (forging object references).
- The Result: In a controlled environment with certain security features (like sandboxing) disabled, the AI achieved arbitrary file read/write access, effectively exfiltrating a "secret" file.

Strategic Outlook for CTI

This case study serves as an early warning sign. While AI is not yet "push-button" for full-chain browser exploits, its ability to automate the most tedious parts of vulnerability research (scanning, primitive building, and PoC generation) is accelerating.

Conclusion: Organizations should anticipate a surge in AI-discovered vulnerabilities. The "window of opportunity" for defenders to patch is shrinking as AI-assisted analysis becomes a standard tool in both red-team and adversary toolkits.

